Content

History of Changes in documented information 1

Abstract 3

Data Classification Policy 3

Purpose and Scope 3

Background 3

Policy 3

Appendix A: Handling of Classified Information 5

Data Retention Policy 9

The Purpose of Data Retention 9

Guiding Data Retention Principles 9

General Retention Policy 10

Appropriate Retention Period 10

Handling Data During the Retention Period 11

Expiration of the Retention Period 11

Data Storage 11

Local Law Consideration 12

Disciplinary 12

History of Changes in documented information

Date	Created by	ID	Version	Change
26.04.2020.	Hrvoje Kovačević	DSIL	1.0	Initial document created.
09.07.2020.	Hrvoje Kovačević	DSIL	1.1	Adds Data Retention policy.
21.06.2021	Hrvoje	DSIL	1.2	Updated

	Kovačević			

Abstract

The purpose of this document is to research the role of the Data Security (DS), Data Classification (DC), Data Retention, and Information Lifecycle Management (ILM) processes in Mindsmiths.

Data Classification Policy

Purpose and Scope

This data classification policy defines the requirements to ensure that information within Mindsmiths is protected at an appropriate level.

This policy applies to all individuals and systems that have access to information kept by Mindsmiths.

Background

This policy defines the high level objectives and implementation instructions for Mindsmiths data classification scheme. This includes data classification levels, as well as procedures for the classification, labeling and handling of data within Mindsmiths.

Policy

1. If classified information is received from outside Mindsmiths, the person who receives the information must classify it in accordance with the rules prescribed in this policy. The person thereby will become the owner of the information.
2. If classified information is received from outside Mindsmiths and handled as part of business operations activities (e.g., customer data on provided cloud services), the information classification, as well as the owner of such information, must be made in accordance with the specifications of the respective customer service agreement and other legal requirements.
3. When classifying information, the level of confidentiality is determined by:
    a. The value of the information, based on impacts identified during the risk

assessment process.

b. Sensitivity and criticality of the information, based on the highest risk calculated for each information item during the risk assessment.

c. Legal, regulatory and contractual obligations.

d. Information must be classified based on confidentiality levels as defined in Table 1.

e. Information and information system owners should try to use the lowest confidentiality level that ensures an adequate level of protection, thereby avoiding unnecessary production costs.

f. Information classified as "Restricted" or "Confidential" must be accompanied by a list of authorized people in which the information owner specifies the names or job functions of people who have the right to access that information.

g. Information classified as "Internal Use" must be accompanied by a list of authorized people only if individuals outside Mindsmiths will have access to the document.

h. Information and information system owners must review the confidentiality level of their information assets every five years and assess whether the confidentiality level should be changed. Wherever possible, confidentiality levels should be lowered.

4. For cloud-based software services provided to customers, system owners under Mindsmiths' control must also review the confidentiality level of their information systems after service agreement changes or after a customer's formal notification. Where allowed by service agreements, confidentiality levels should be lowered.

5. Information must be labeled according to the following:

   a. Paper documents: the confidentiality level is indicated on the top and bottom of each document page; it is also indicated on the front of the cover or envelope carrying such a document as well as on the filing folder in which the document is stored. If a document is not labeled, its default classification is Internal Use.

   b. Electronic documents: the confidentiality level is indicated on the top and bottom of each document page. If a document is not labeled, its default classification is Internal Use.

   c. Information systems: the confidentiality level in applications and databases must be indicated on the system access screen, as well as on the screen when displaying such information. If the screen does not indicate the confidentiality level its default classification is Internal Use.

d. Electronic mail: the confidentiality level is indicated in the first line of the email body. If it is not labeled, its default classification is "Internal Use".

e. Electronic storage media (disks, memory cards, etc.): the confidentiality level must be indicated on the top surface of the media. If it is not labeled, its default classification is "Internal Use".

6. All people accessing classified information must follow the guidelines listed in Appendix A, "Handling of Classified Information."
7. All people accessing classified information must first gain the permission from the data owner following the proper processes and policies compliances.
8. Incidents related to the improper handling of classified information must be reported in accordance with the Security Incident Management Policy.

Confidentiality Level	Label	Classification Criteria	Access Restrictions
Public	For Public Release	Making the information public will not harm Mindsmiths in any way.	Information is available to the public.
Internal Use	Internal Use	Unauthorized access may cause minor damage and/or inconvenience to Mindsmiths.	Information is available to all employees and authorized third parties.
Restricted	Restricted	Unauthorized access to information may cause considerable damage to the business and/or Mindsmiths reputation.	Information is available to a specific group of employees and authorized third parties.
Confidential	Confidential	Unauthorized access to information may cause catastrophic damage to business and/or Mindsmiths reputation.	Information is available only to specific individuals in Mindsmiths.

Table 1: Information Confidentiality Levels

Appendix A: Handling of Classified Information

Information and information systems must be handled according to the following guidelines*:

1. Paper Documents
    a. Internal Use
        i. Only authorized people may have access.
        ii. If sent outside Mindsmiths, the document must be sent as registered mail.
        iii. Documents may only be kept in rooms without public access.
        iv. Documents must be removed expeditiously from printers and fax machines.
    b. Restricted
        i. The document must be stored in a locked cabinet.
        ii. Documents may be transferred within and outside Mindsmiths only in a closed envelope.
        iii. If sent outside Mindsmiths, the document must be mailed with a return receipt service.
        iv. Documents must immediately be removed from printers and fax machines.
        v. Only the document owner may copy the document.
        vi. Only the document owner may destroy the document.
    c. Confidential
        i. The document must be stored in a locked cabinet.
        ii. The document may be transferred within and outside Mindsmiths only by a trustworthy person in a closed and sealed envelope.
        iii. Faxing the document is not permitted.
        iv. The document may be printed only if the authorized person is standing next to the printer.
2. Electronic Documents
    a. Internal Use
        i. Only authorized people may have access.
        ii. When documents are exchanged via unencrypted file sharing

services such as FTP, they must be password protected.

iii. Access to the information system where the document is stored must be protected by a strong password.

iv. The screen on which the document is displayed must be automatically locked after 10 minutes of inactivity.

b. Restricted

i. Only people with authorization for this document may access the part of the information system where this document is stored.

ii. When documents are exchanged via file sharing services of any type, they must be encrypted.

iii. Only the document owner may erase the document.

c. Confidential

i. The document may be stored only on servers which are controlled by Mindsmiths.

ii. The document may only be shared via file sharing services that are encrypted such as HTTPS and SSH. Further, the document must be encrypted and protected with a string password when transferred.

3. Information Systems

a. Internal Use

i. Only authorized people may have access.

ii. Access to the information system must be protected by a strong password.

iii. The screen must be automatically locked after 10 minutes of inactivity.

iv. The information system may be only located in rooms with controlled physical access.

b. Restricted

i. Users must log out of the information system if they have temporarily or permanently left the workplace.

ii. Data must be erased only with an algorithm that ensures secure deletion.

c. Confidential

i. Access to the information system must be controlled through multi-factor authentication (MFA).

ii. The information system may only be installed on servers controlled

by Mindsmiths.

iii. The information system may only be located in rooms with controlled physical access and identity control of people accessing the room.

4. Electronic Mail
    a. Internal Use
        i. Only authorized people may have access.
        ii. The sender must carefully check the recipient.
        iii. All rules stated under “information systems” apply.
    b. Restricted
        i. Email must be encrypted if sent outside Mindsmiths-Client communication channels.
    c. Confidential
        i. Email must be encrypted if sent outside Mindsmiths-Client communication channels.
5. Electronic Storage Media
    a. Internal Use
        i. Only authorized people may have access.
        ii. Media or files must be password protected.
        iii. If sent outside Mindsmiths, the medium must be sent as registered mail.
        iv. The medium may only be kept in rooms with controlled physical access.
    b. Restricted
        i. Media and files must be encrypted.
        ii. Media must be stored in a locked cabinet.
        iii. If sent outside Mindsmiths, the medium must be mailed with a return receipt service.
        iv. Only the medium owner may erase or destroy the medium.
    c. Confidential
        i. Media must be in a locked cabinet.
        ii. Media may be transferred within and outside Mindsmiths only by a trustworthy person and in a closed and sealed envelope.

6. Information Transmitted Orally
    a. Internal Use
        i. Only authorized people may have access to information.
        ii. Unauthorized people must not be present in the room when the information is communicated.
    b. Restricted
        i. The room must be sound-proof.
        ii. The conversation must not be recorded.
    c. Confidential
        i. No transcript of the conversation may be kept.

In this document, controls are implemented cumulatively, meaning that controls for any confidentiality level imply the implementation of controls defined for lower confidentiality levels - if strict controls are prescribed for a higher confidentiality level, then only such controls are implemented.

Data Retention Policy

The Purpose of Data Retention

1. This policy must be followed whenever Personal Data is processed for or on behalf of Mindsmiths.
2. The General Data Protection Regulation (EU) 2016/679 (GDPR) sets out specific requirements regarding the retention of Personal Data. In particular:
    a. To the extent that the data records of Mindsmiths (Data Records) contain Personal Data, Mindsmiths must comply with applicable data protection laws, including (where relevant) the GDPR.
    b. The GDPR requires Personal Data to be deleted or anonymized when they are no longer needed given the purposes for which they are held.
3. The purpose of this Policy is to ensure that:
    a. Data Records are adequately protected and maintained;
    b. Data Records containing Personal Data, which are no longer required are discarded at the appropriate time;
    c. Mindsmiths's data retention principles will help Mindsmiths to ensure the exercise of individuals' data protection rights.
4. Capitalized terms not defined directly in this Policy have the meaning assigned to them in a document connected to this Policy in the form of the Data Protection Policy.

Guiding Data Retention Principles

1. These are Mindsmiths' guiding data retention principles:
    a. **Fairness**: All Processing of Personal Data must be fair, proportionate, and compatible with the purposes for which the data were collected.
    b. **Necessity**: Personal Data is deleted when no longer needed.
    c. **Security**: Personal Data is protected by appropriate security measures.
2. It needs to be ensured that each principle set out above is followed whenever a processing activity is carried out or planned for or on behalf of Mindsmiths.

General Retention Policy

1. Personal Data should only be retained for the period "necessary" to achieve our Processing purposes. This means that Personal Data must be deleted when we no longer need such data, for example, where:
    a. the Personal Data is incorrect;
    b. the relevant contract has already been performed and possible claims are time-barred; or
    c. an individual has withdrawn their consent to the Processing (i.e. if consent constitutes a basis for the Processing).
2. Mindsmiths' legal unit should be consulted prior to deletion of any Personal Data. Prior to deleting any Personal Data, Mindsmiths' legal unit should establish whether the limitation periods for any related claims have elapsed, whether the run of the limitation period has been interrupted and whether any related claims have been brought up.
3. Legal or regulatory requirements might require Personal Data to be retained for a specified period. For example:
    a. tax law;
    b. labour law.
4. You must therefore consider for each Processing activity:
    a. whether any legal or regulatory requirements specify a retention period for Personal Data to be processed;
    b. how long will Mindsmiths need to retain Personal Data in relation to the proposed Processing activity; and
    c. whether the duration of the proposed retention period is necessary for the purposes of the relevant Processing activity.
5. The retained data should be subject to periodic reviews every 6 months with an aim of identifying the data that should be deleted.

Appropriate Retention Period

1. For each new project or any business and general organizational work tied to the Personal Data or data in general data retention period should be defined by an owner assigned to the data.
2. The data owner will inform the Data Protection Coordinator of the proposed

retention period of the relevant Personal Data (a Retention Notice).

3. Promptly after the receipt of a Retention Notice, the Data Protection Coordinator will:
    a. verify whether there are any relevant legal or regulatory requirements that will impact the proposed retention period set out in the Retention Notice; and
    b. provide a confirmation, in writing, by e-mail or verbally, that the proposed retention period complies with this Policy (Confirmation).
4. Each member of personnel (including an employee and associate) of Mindsmiths must ensure that any new Processing activities are promptly notified to the data owner and that the retention period is promptly updated.
5. Continual recording of: (i) Confirmations; and (ii) each retention period agreed for Mindsmiths is important for record-keeping requirements..

Handling Data During the Retention Period

1. Regulators and individuals may request access to, or enabling the audit of, the Personal Data that Mindsmiths Processes.
2. Mindsmiths creates and stores Processed Personal Data in secure systems in accordance with auditable processes. In particular, Mindsmiths ensures that all Personal Data is kept secure (i.e. so as to avoid unauthorized access, alteration, destruction, deletion or tampering in any way for the approved retention period of relevant Personal Data).
3. It is necessary to ensure that the Processed Personal Data is capable of deletion, correction (in response to an individual exercising their Personal Data protection rights). Mindsmiths preserves the integrity of all Processed Personal Data. In particular, it ensures that:
    a. Processed Personal Data is not manipulated or altered;
    b. any corrections are explicable – Mindsmiths is able to promptly track and justify changes.
4. Mindsmiths, as soon as practicable, responds to requests from individuals, regulators and other competent authorities to provide information . Mindsmiths ensures that third-party service providers/vendors:
    a. secure Personal Data that they Process on behalf of Mindsmiths in accordance with all relevant legal and regulatory requirements.
5. When you are negotiating contracts with service providers where Personal Data will be processed on Mindsmiths' behalf, contact the Data Protection Coordinator for guidance on implementing and reflecting these requirements in the applicable contractual documentation.

Expiration of the Retention Period

1. Data Records must be destroyed responsibly and systematically.
2. No records that may be relevant in any current or expected litigation, dispute resolution, or regulatory inquiry may be destroyed under any circumstances

without a prior Confirmation from the Data Protection Coordinator. If in any doubt as to the relevance of any record in relation to current or expected litigation, dispute resolution or regulatory inquiry, contact the Data Protection Coordinator.

Data Storage

1. Mindsmiths maintains a detailed record of our Processing of Personal Data to comply with applicable laws (including data access obligations and security breach notification requirements) (the Record of Processing). The Record of Processing describes, among other things:
    a. the location in which the Processed Personal Data is held/stored (e.g. paper files, third party servers, our servers, backup storage);
    b. the purposes of the Processing;
    c. the legal basis on which Mindsmiths is processing the relevant data; and
    d. retention periods.
2. The Data Protection Coordinator is responsible for maintaining the Record of Processing.
3. Each member of personnel (including employee and associate) of Mindsmiths should contribute to updating and maintaining the Record of Processing.

Local Law Consideration

1. This Policy has been drawn up in accordance with the requirements of the GDPR and the provisions of Croatian law. If the Policy were to be applicable outside of Croatia, the principles laid down in paragraph Guiding Data Retention Principles applies.
2. Where any local legal or regulatory requirements impose additional or more restrictive standards than this Policy, such jurisdictional specific policies shall take precedence.
3. Contact your Data Protection Coordinator if this Policy conflicts with local laws in any way.

Disciplinary

1. Mindsmiths takes its data retention obligations seriously. Mindsmiths will, if required, report violations of this Policy and related provisions to relevant regulatory, governmental and other competent authorities.
2. It is your responsibility to comply with this Policy. Failure to comply may leave you personally liable for civil or criminal penalties (including civil or criminal penalties and fines).
3. Breaches of this Policy are recorded and monitored. Failure to comply may be taken into account during performance reviews for Mindsmiths's employees, associates and service providers.